Security Review

Curve access controls & remediation plan

PRELIMINARY • READ-ONLY ASSESSMENT

29 October 2026 | X Layer mainnet · Chain ID 196

The tested rejection paths work. A complete bypass of the Agentic Wallet restriction has not been demonstrated.

This review examined whether Starx restricts bonding-curve trading to OKX Onchain OS Agentic Wallets. Public bytecode, pinned blockchain snapshots and selected client-source paths were inspected. Four zero-amount read-only simulations confirmed the expected rejection behavior.

DECISION FOR THE TEAM

Treat wallet-provenance enforcement as an open assurance question. The Starx gate checks delegation codehash and transaction gas price; the reviewed evidence does not establish the complete authorization behavior of the deployed SmartWallet.

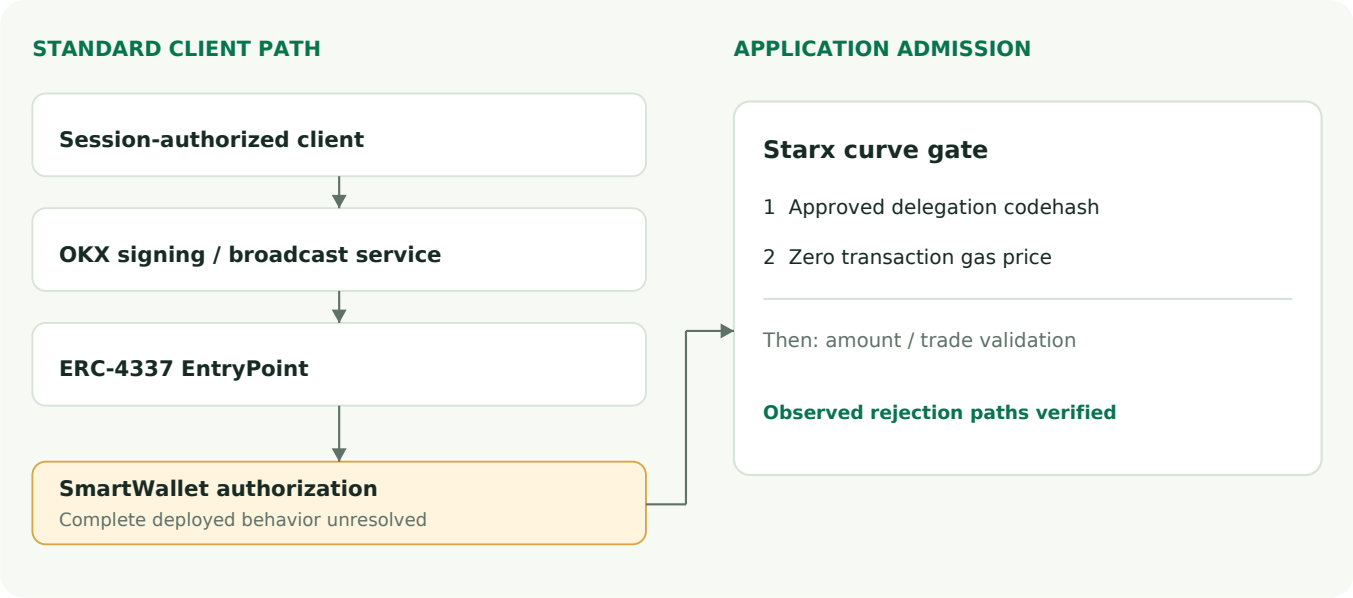
Item	Classification	Priority
SR-01 · Wallet provenance	Architecture risk; exploit unconfirmed	P1
SR-02 · Administrative changes	Confirmed design property	P2
SR-03 · Source verification	Review-completion blocker	P1
SR-04 · Curve / pool scope	Expected behavior; documentation	P3

Priorities describe the proposed order of work. They are not CVSS scores or confirmed exploit severities. All remediation below is proposed; no contract, application or wallet changes were deployed.

01 / SCOPE & TRUST BOUNDARIES

Scope & trust boundaries

The review covered the public Starx frontend and npm CLI, contract ABIs and bytecode, blockchain getters, selected Onchain OS authorization paths, and the X Layer gasless mechanism. It focused on admission to the bonding curve, not the entire trading platform.



What was verified

- Live configuration at two pinned X Layer blocks; proxy implementation and matching runtime-code hash.
- The active token has graduated = false and locked = true.
- Ordinary-address rejection, and the gas-price rejection for an address with approved delegation.
- Gasless-target whitelist observations and the standard client path using an access token, session certificate and session signatures.

What remains outside the evidence

A successful nonzero trade, a complete alternative UserOperation, the deployed SmartWallet signature-validation paths, server-side OKX authorization, and full Solidity-level coverage were not established. Reentrancy, reserve accounting, rounding, MEV, API abuse and general frontend security were not comprehensively audited.

METHOD

Only public reads and zero-amount eth_call simulations were used. No wallet login, private-key access, signatures, approvals, transfers, transaction broadcasts, state overrides or account unlocking occurred.

The from field in eth_call selects a simulated caller. It does not establish control over that address or prove that a corresponding transaction can be signed and included.

02 / OBSERVED BEHAVIOR & TEST RESULTS

Observed behavior & test results

The relevant active-curve token is 0x303d2f498bc46eE9963d517Dd12D34A115f5Cb8b. Results below are pinned to block 74,498,680. Every simulated trade used zero token amounts and zero native value.

Simulated condition	Observed result	What this establishes
Ordinary address · buy · gas price 0	NotAgentWallet	Wallet gate rejects this caller
Ordinary address · sell · gas price 0	NotAgentWallet	Wallet gate rejects this caller
Approved delegation · buy · gas price 20,000,000 wei	NotSponsored	Nonzero gas price is rejected
Approved delegation · buy · gas price 0	ZeroAmount	Execution reaches amount validation

Calls: buy(token, 0, 0) and sell(token, 0, 0). ZeroAmount is a revert, not a successful trade. These are narrow rejection checks, not full-path or invariant tests.

Reconstructed Starx admission logic

The shared bytecode routine at program counter 0x388d corresponds to the following pseudocode. This is a reconstruction from ABI and opcodes, not verified Solidity source.

```
if (!allowedCodehash[msg.sender.codehash])
    revert NotAgentWallet(msg.sender);
if (gaslessRequired && tx.gasprice != 0)
    revert NotSponsored();
```

Additional observations

- The ordinary probe address has empty code and isAgentWallet = false.
- The token creator has the approved 23-byte EIP-7702 delegation indicator and isAgentWallet = true.
- gaslessRequired = true; paused = false; upgradesFrozen = false.
- The ERC-4337 EntryPoint is a permitted full gasless target. The launchpad itself is not a permitted full gasless target.

Evidence: token-303d-snapshot.json. The earlier block 74,498,079 independently records the allowed delegation codehash and additional whitelist getters.

03 / SR-01 · WALLET PROVENANCE ASSURANCE

SR-01 · Wallet provenance assurance

P1 Architecture risk

Complete exploitability is unresolved

Observation

The Starx predicate recognizes an approved delegation codehash. EIP-7702 permits an EOA owner to authorize the same delegation indicator regardless of where that EOA was created. Matching code therefore establishes a delegation target, not creation or custody inside an OKX TEE. [S1]

The zero-gas-price condition adds an execution-policy requirement. The observed X Layer whitelist allows the public ERC-4337 EntryPoint as a gasless target, so gas price alone is not an independent attestation of wallet origin. EntryPoint and SmartWallet authorization still apply. [S2, S3]

Impact and uncertainty

If an independently controlled account could satisfy the deployed SmartWallet authorization and network-inclusion requirements, the Starx gate alone would not prove OKX wallet provenance. That end-to-end condition was not tested or demonstrated. The reviewed client code uses authenticated OKX APIs and session certificates, but it does not reveal every alternative path accepted by the deployed SmartWallet. [S4, S5]

Recommended remediation

- Define the intended policy: approved wallet implementation, OKX-created wallet provenance, or per-trade approval. These are distinct requirements.
- If provenance is required, use an enrollment registry or attestation issued by a source capable of verifying that provenance. Confirm provider support; no ready-made OKX attestation integration was established in this review.
- For action permits, bind the signer authorization to chain ID, verifying contract, wallet, operation, token, amounts, nonce and expiry. A wallet self-signature alone does not establish external provenance.
- Specify revocation and key-control-change behavior. Apply one consistent admission policy across create, buy and sell, with any exit-only exception explicitly designed and tested.

ACCEPTANCE CRITERIA

A local test must show that an unregistered account with the same delegation is rejected; replayed, expired, cross-chain and wrong-contract permits are rejected; revocation takes effect; and correctly enrolled wallets retain the intended functionality.

Proposed owners: smart-contract engineering and security, with the OKX integration owner. No owner assignment or remediation completion has been confirmed.

04 / GOVERNANCE & PRODUCT BOUNDARIES

Governance & product boundaries

SR-02 · Admission rules remain changeable

P2 Confirmed design property

Governance hardening; no outsider exploit shown

The launchpad is a proxy with a nonzero owner and upgradesFrozen = false. Its ABI exposes setGaslessRequired, setImpl and upgradeToAndCall; ownership checks were observed in the relevant setter bytecode. This makes administrative control part of the security model. It is not, by itself, a vulnerability.

- Document the authority to change implementations and admission rules.
- Evaluate multisig approval and a timelock for sensitive changes; separately define any emergency powers.
- Monitor implementation, owner, allowed-codehash and gasless-policy changes. Record each approved deployment.
- Only consider an irreversible upgrade freeze if the intended governance model requires it and the implementation has completed review.

Acceptance: unauthorized callers cannot change settings; the intended approval process is tested; monitoring detects relevant changes. Proposed owners: protocol engineering and operations.

SR-04 · Clarify curve versus pool restrictions

P3 Expected behavior

Documentation and test-scope correction

The earlier STARX token at 0x795805EC11760cc2fdd69FaEef494a5E380B93b7 had graduated = true when read. The public Starx CLI README describes open trading in Uniswap V4 pools after graduation. A pool trade therefore does not demonstrate bypass of a curve-only restriction. [S6]

- Describe the restriction explicitly as applying to the bonding-curve phase wherever that is the intended policy.
- Keep curve and post-graduation pool tests separate. Check graduated at the pinned test block.
- Define the restricted contract, method, phase and admissible evidence in any public security challenge.

Acceptance: product documentation and the challenge scope consistently describe graduation behavior. Proposed owners: product and protocol engineering.

05 / SR-03 · COMPLETE SOURCE VERIFICATION

SR-03 · Complete source verification

P1 Review-completion blocker

Evidence limitation; not a demonstrated product bug

Verified Solidity source matching the deployed Starx launchpad and the exact approved SmartWallet implementation was not obtained. Explorer requests were inaccessible in the review environment; the checked Sourcify lookups returned 404. This does not prove that source is unpublished.

Repository reviewed	Relevant role	Coverage achieved
okx/agent-trade-kit	Exchange-account MCP / CLI	README and repository structure
okx/agent-skills	Exchange-operation instructions	README and repository structure
okx/xlayer-reth	X Layer execution / gasless integration	Selected source and dependency tracing
okx/onchainos-skills	Agentic Wallet client	Selected session, signing and broadcast paths

The four pinned repository trees contain no .sol files for these contracts. The execution-client dependency has separate whitelist Solidity source, which informed the gasless analysis. None of this substitutes for matching the deployed SmartWallet source and its signature-validation behavior.

Required evidence package

- Exact Starx and SmartWallet source commits, ABIs, compiler versions, optimizer / via-IR settings, library links and immutable values.
- Deployment manifests connecting proxy, implementation, token implementation, hook, router, owner and chain ID.
- A reproducible runtime-bytecode match, including constructor and immutable handling.
- Documented signing modes, validator / module configuration, EntryPoint versions and required external authorizers.

CLOSURE

Close this item only after source-to-bytecode matching and the agreed local validation suite. Until then, report the result as a preliminary access-control review, not a complete audit or proof of safety.

Proposed owners: protocol engineering, the OKX integration owner and security. The available client code demonstrates a session-authorized service path; backend enforcement was not audited.

06 / REMEDIATION & VALIDATION PLAN

Remediation & validation plan

The following backlog is proposed for the team. Priorities are relative; no delivery dates, named assignees or completed fixes are implied.

Seq.	Work item	Proposed owner	Done when
1	Define the exact admission invariant (SR-01)	Product + security	Policy and intended exceptions approved
1	Obtain and match deployed sources (SR-03)	Protocol + integration	Reproducible bytecode match
2	Test the complete authorization boundary locally	Security + protocol	Expected accept / reject matrix passes
3	Implement provenance / permit controls if required	Smart-contract engineering	Implementation and regression tests pass
3	Harden administration (SR-02)	Protocol + operations	Change controls and monitoring verified
3	Align documentation (SR-04)	Product + protocol	Curve / pool scope is explicit

Local validation suite to add

- Authorization: plain EOA, approved / unapproved delegation, enrolled / unenrolled wallet, revoked wallet and supported UserOperation signing modes.
- Consistency: create, initial buy, buy and sell; any deliberately permitted withdrawal or exit path.
- Permits, if introduced: nonce reuse, expiry, wrong action / amount / token, chain and contract separation, and signer rotation.
- Governance: proxy initialization, owner transfer, allowed implementation changes, policy toggles and upgrades.
- Broader protocol review: callbacks / reentrancy, quote-token behavior, reserve invariants, rounding, wallet caps and graduation.

These are proposed tests. They were not executed in this review. Use a controlled local fork or isolated test deployment, with meaningful nonzero values and full signature / execution paths.

RECOMMENDED STATUS WORDING

The tested ordinary-wallet and nonzero-gas-price calls are rejected. No unauthorized curve trade has been demonstrated. Full wallet-provenance assurance remains open pending source matching and complete authorization tests.

07 / TECHNICAL APPENDIX

Technical appendix

Component	Address / value
Network	X Layer mainnet · chain ID 196
Launchpad proxy	0x37a3889888999c126D9E3e70ab8037fe486C9551
Launchpad implementation	0x538af113368cbdfcd2c590d884ba8a95a4c3fa72
Approved wallet implementation	0xe40ccb2d94975c51bff0c004efdfd9b3a5796fa4
Active curve token	0x303d2f498bc46eE9963d517Dd12D34A115f5Cb8b
Token implementation	0xf73590eed5d5226bd1f4b8b719fabd0e9df575ba
EntryPoint v0.7	0x0000000071727De22E5E9d8BAf0edAc6f37da032
Gasless whitelist	0x19787404b0c70021b4752028f7e3a92313885B27
Launchpad owner	0x623f089bbb315de3497814a3077903a9809ca95d

Pinned blocks

Initial state: block 74,498,079.

```
0x372286ef326f6b635e1c65929c35e6c3134acd5e88754acade3f381e703b8e25
```

Active-curve checks: block 74,498,680.

```
0x6ec0440483ca9e45bcf32f4270461adf8e9eefff26696dfd6ab84d4431fb4124
```

Implementation identity

The launchpad implementation code is 16,586 bytes. Its Keccak-256 hash matches across the two snapshots:

```
0xcec8a95b76f4535024d0b7fb3423d0f9677d2b8769bdc818c81bf72e735cb215
```

The earlier graduated-token reads used latest independently of the pinned active-curve snapshot. All configuration statements in this report describe the observed snapshots, not guaranteed future state.

08 / SOURCES & EVIDENCE HANDOFF

Sources & evidence handoff

Repository versions

Repository	Commit
okx/agent-trade-kit	`e5b60e4f0bc2afc75fab19c8360dafa6b84f3ed7`
okx/agent-skills	`f299d194d36c626a9a1d9a50245c8e1640b62230`
okx/xlayer-reth	`d32b20beed8c8b56a2449f00a24fe26288a55d48`
okx/onchainos-skills	`73904b636a0f022dcc13b6d7a0dd2ed3b3195f25`

Primary references

S1 EIP-7702: delegation indicators and transaction origination

S2 X Layer gasless execution integration · pinned source

S3 Gasless whitelist rules · pinned source

S4 Onchain OS: unsigned-info and broadcast API client

S5 Onchain OS: session signatures and EIP-712 signing path

S6 Starx CLI 1.0.1 · package metadata and archived README

The reviewed whitelist source was not fully matched to its live runtime code. Whitelist values cited in the report were read directly from the chain.

Evidence included with the report

- Initial and active-token RPC snapshots, whitelist responses, earlier-token state and repository commit manifest.
- Launchpad disassembly, the read-only state helper, and the archived public CLI README / ABI.
- A SHA-256 manifest for detecting changes to the delivered evidence files.

Raw RPC responses are observed evidence. Reconstructed pseudocode, architecture risks and proposed fixes are analysis. Suggested owners, priorities and acceptance tests are recommendations. This report was prepared with AI assistance and is not a formal security certification.